

1.Incident Analysis

1.1 Timeline

Time	Description	User/Host	Suspicios IP	Source
2024-10-15 06:47:15	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:18	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:21	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:24	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:27	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:30	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:33	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:36	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:39	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:42	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:45	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:48	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:51	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:54	IDOR	1523	203.0.113.45	API Logs
2024-10-15 06:47:57	IDOR	1523	203.0.113.45	API Logs
2024-10-15 09:00:23	Email Phishing	security@acme-finance.com	203.0.113.45	Email Logs
2024-10-15 09:00:25	Email Phishing	security@acme-finance.com	203.0.113.45	Email Logs
2024-10-15 09:00:27	Email Phishing	security@acme-finance.com	203.0.113.45	Email Logs
2024-10-15 09:00:29	Email Phishing	security@acme-finance.com	203.0.113.45	Email Logs
2024-10-15 09:00:31	Email Phishing	security@acme-finance.com	203.0.113.45	Email Logs
2024-10-15 09:00:33	Email Phishing	security@acme-finance.com	203.0.113.45	Email Logs
2024-10-15 09:23:45	SQL Injection	1523	203.0.113.45	Web Logs -Waf Logs
2024-10-15 09:24:10	Data Export	1523	203.0.113.45	Web Logs

1.2 Attack Vector Identification

Phishing

To deceive users, an email was sent from a fake domain (acme-finans.com) similar to the company domain.

The emails contained subject lines that would cause users to panic.

Users may have entered their credentials by clicking on the redirect link.

2024-10-15 09:00:23	security@acme-finance.com	user1@acme.com	URGENT: Verify Your Account - Action Required	yes	203.0.113.45
2024-10-15 09:00:25	security@acme-finance.com	user2@acme.com	URGENT: Verify Your Account - Action Required	no	
2024-10-15 09:00:27	security@acme-finance.com	user3@acme.com	URGENT: Verify Your Account - Action Required	yes	203.0.113.45
2024-10-15 09:00:29	security@acme-finance.com	user4@acme.com	URGENT: Verify Your Account - Action Required	no	
2024-10-15 09:00:31	security@acme-finance.com	user5@acme.com	URGENT: Verify Your Account - Action Required	yes	203.0.113.45
2024-10-15 09:00:33	security@acme-finance.com	user6@acme.com	URGENT: Verify Your Account - Action Required	no	

Broken Access Control - API

After logging in as user1523 via the IP address 203.0.113.45, the attacker exploited an IDOR vulnerability to access other users' portfolio data.

2024-10-15 06:46:30	1523	/api/v1/portfolio/1523	GET	1523	200	156	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:15	1523	/api/v1/portfolio/1524	GET	1524	200	143	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:18	1523	/api/v1/portfolio/1525	GET	1525	200	138	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:21	1523	/api/v1/portfolio/1526	GET	1526	200	147	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:24	1523	/api/v1/portfolio/1527	GET	1527	200	141	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:27	1523	/api/v1/portfolio/1528	GET	1528	200	139	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:30	1523	/api/v1/portfolio/1529	GET	1529	200	144	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:33	1523	/api/v1/portfolio/1530	GET	1530	200	142	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:36	1523	/api/v1/portfolio/1531	GET	1531	200	148	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:39	1523	/api/v1/portfolio/1532	GET	1532	200	145	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:42	1523	/api/v1/portfolio/1533	GET	1533	200	140	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:45	1523	/api/v1/portfolio/1534	GET	1534	200	146	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:48	1523	/api/v1/portfolio/1535	GET	1535	200	143	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:51	1523	/api/v1/portfolio/1536	GET	1536	200	149	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:54	1523	/api/v1/portfolio/1537	GET	1537	200	141	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen
2024-10-15 06:47:57	1523	/api/v1/portfolio/1538	GET	1538	200	147	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen

SQL Injection

SQL patterns were detected in requests made to the /dashboard/search endpoint from the same IP (203.0.113.45).

SQL injection was successfully performed on the database by bypassing the WAF.

After attempts using the SQL injection payload were blocked, it was observed that they were bypassed.

After being bypassed, the database was exported.

2	2024-10-15 09:20:30	981173	HIGH	DETECT	203.0.113.45	/dashboard/search	SQL Injection Attempt - OR 1=1	yes
3	2024-10-15 09:21:15	981318	CRITICAL	BLOCK	203.0.113.45	/dashboard/search	SQL Injection - DROP TABLE	yes
4	2024-10-15 09:22:00	981257	HIGH	BLOCK	203.0.113.45	/dashboard/search	SQL Injection - UNION SELECT	yes
5	2024-10-15 09:23:45	981001	MEDIUM	DETECT	203.0.113.45	/dashboard/search	Suspicious SQL Pattern	no

2024-10-15 09:23:45,1523,/dashboard/search,ticker=AAPL' /*!50000R*/ 1=1--,200,156789,203.0.113.45

2024-10-15 09:24:10,1523,/dashboard/export,format=csv,200,892341,203.0.113.45,I

1.3 Saldırı Sınıflandırması

<u>Detected Vulnerability</u>	<u>MITRE ATT&CK</u>	<u>Tactic</u>	<u>OWASP Top 10 (2021)</u>	<u>Description</u>
<u>Email Phishing</u>	T1566	<u>Initial Access</u>	<u>Social Engineering / Awareness Gap</u>	<u>Attempt to gain access by deceiving users.</u>
<u>IDOR (Insecure Direct Object Reference)</u>	T1530 / T1005	<u>Privilege Escalation / Exfiltration</u>	<u>A01 – Broken Access Control</u>	<u>Unauthorized access to user data via direct object references.</u>
<u>SQL Injection</u>	T1190	<u>Initial Access / Execution</u>	<u>A03 – Injection</u>	<u>Malicious SQL queries used to manipulate or extract data.</u>

1.4 Root Cause Analys

Red team service It has been assessed that this could be done as part of the penetration test conducted by the External Security Company before October 20-25. The company providing the service should be asked to confirm why this work was done earlier than the expected date. It has been observed that users who clicked on the phishing email lacked awareness. The IDOR vulnerability must be addressed on endpoints with broken access control. The SQL Injection vulnerability must be addressed at the code level, and the rules in the WAF product must be updated.

1.5 Impact Assestment

In the phishing email, users user1, user3, and user5 appear to have clicked on the links sent in the email. Users may have shared their account information with the attacker. They should be asked to change their passwords. In the IDOR security vulnerability, portfolio data belonging to users with ID numbers in the range 1524-1538 was accessed. The data was extracted using an SQL injection attack in the Search field.

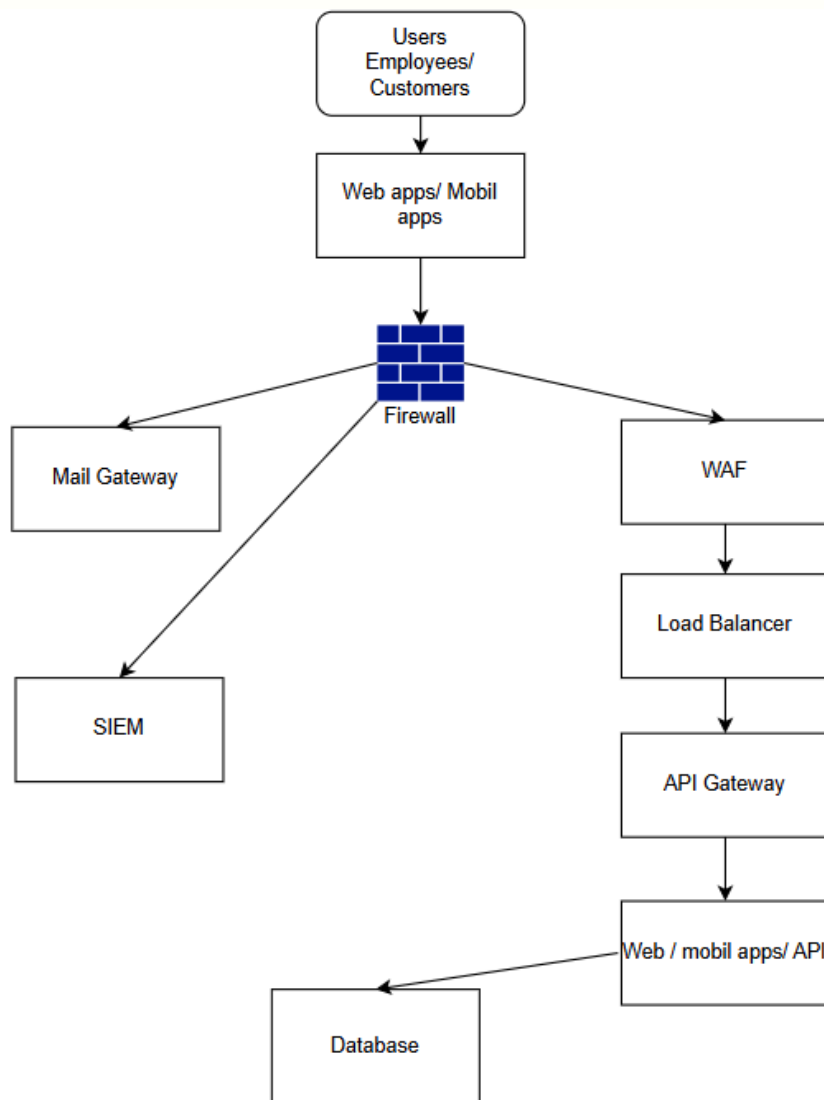
2. Architecture Review

2.1 Current Architecture Weaknesses

There is no firewall in the current structure. A firewall product is required to manage network traffic. The firewall has IPS, so it has not been added to the topology. The WAF product should be placed behind the firewall. The SIEM product should be included in the architecture.

2.2 Improved security architecture diagram

The secure architecture is as follows.



2.3 Recommended security controls

Rules can be written with the SIEM product. In API logs, we can generate an alert when someone else's token is used to access another user's data for an IDOR vulnerability in the portfolio endpoint. For SQL injection vulnerabilities, if a Suspicious SQL Pattern and an unblocked log come in the WAF product, we can generate an alert in SIEM.

2.3 Defense-in-depth strategy

Alarms should be generated by SIEM before and when incidents occur. When alarms are generated, they should be investigated and addressed. Security products should be tightened. Vulnerabilities identified in penetration testing should be closed.

3. Response & Remediation

Passwords of users who click on links in phishing emails will be changed, and users may be provided with awareness training. The domain from which the email originated is blocked in the Mail Gateway.

Software developers are notified of the IDOR vulnerability and requested to perform ownership checks in the code to address the vulnerability. A user should not be able to access another user's data.

Software developers are contacted regarding the SQL injection vulnerability. Software developers are informed that user input should not be placed directly into the SQL query. The reason for WAF bypass should be investigated, and rules should be written accordingly.

User passwords are changed within 0-24 hours. IP blocking can be implemented. Domains can be blocked. Emails can be deleted from users.

Exploited vulnerabilities are fixed by developers within 1 week.

Security enhancements are implemented in security products within 1-3 months.